

ShadowAI Detection & Control Checklist

1. VISIBILITY

DNS monitoring

Monitor DNS queries to detect connections to AI services, model repositories, or unknown inference endpoints

Proxy logs

Capture outbound web traffic to identify AI tool usage, uploads, and data flows

CASB discovery

Use Cloud Access Security Brokers to detect unsanctioned AI SaaS usage across the enterprise

Firewall egress logs

Track outbound connections to AI domains, APIs, and cloud inference services

Identity provider logs

Monitor OAuth grants, token usage, and app consent to detect unauthorized AI integrations

Endpoint telemetry

Collect browser history, clipboard activity, and local AI app usage from endpoints

Network egress anomaly detection

Detect unusual outbound traffic patterns that may indicate AI-related data exfiltration

SaaS access logs

Review logs from M365, Google Workspace, GitHub, Slack, etc., for AI-related activity

Cloud provider logs

Monitor AWS/GCP/Azure logs for AI service usage, model training, and inference calls

Mobile device management logs

Identify AI apps installed or used on managed and BYOD mobile devices

Browser extension inventory

Detect AI-related extensions that may capture or transmit sensitive data

Local LLM runtime detection

Identify local model runtimes such as Ollama, LM Studio, or GPT4All running on endpoints

AI-related API key usage monitoring

Track API key calls to AI services to detect unauthorized or excessive usage

AI container/image scanning

Scan AI-related containers and model images for risks, malware, or unauthorized models

Developer tool telemetry

Monitor AI-enabled IDE extensions (VS Code, JetBrains) for code or data sent to AI tools

2. CONTROLS

AI allow/block list

Define which AI tools are approved or prohibited for enterprise use

OAuth app restrictions

Block or restrict third-party AI apps from connecting to corporate accounts

Browser extension allowlist

Permit only approved extensions to prevent unauthorized AI data capture

Prompt sandboxing

Route prompts through a secure environment that strips sensitive data before reaching AI tools

Conditional access policies

Apply identity-based restrictions to AI tools based on user, device, or location

Data egress controls

Limit token size, rate, and domain access to prevent large data uploads to AI services

AI-specific firewall categories

Use firewall rules to block or restrict access to AI domains and inference endpoints

Endpoint DLP

Prevent sensitive data from being copied, pasted, or uploaded into AI tools

GitHub/GitLab policy enforcement

Block code from being sent to AI tools via IDE plugins or CI/CD pipelines

Enterprise AI gateway

Proxy all AI traffic through a controlled gateway that enforces policy and logs usage

Model-specific guardrails

Apply safety filters and content restrictions to internal LLMs

Secrets scanning

Detect and block secrets before they are sent to AI tools

AI-specific SaaS restrictions

Disable file uploads or chat features in AI-enabled SaaS apps

AI-specific browser isolation

Open AI tools in isolated browser sessions to prevent data leakage

AI-specific API key governance

Control issuance, rotation, and usage of AI-related API keys

AI container registry policies

Restrict which AI models and containers can be pulled or deployed

3. DETECTION

Large POST detection

Detect unusually large uploads that may indicate data being sent to AI tools

AI domain frequency analysis

Identify abnormal patterns of repeated access to AI domains

Prompt-like pattern detection

Detect text patterns resembling prompts, instructions, or code sent to AI tools

DLP for code/PII/secrets

Block sensitive data from being uploaded to AI services

Behavioral analytics

Detect unusual AI usage patterns such as spikes, off-hours activity, or new tools

Sensitive document upload detection

Identify when confidential files are uploaded to AI tools

AI-generated phishing detection

Detect synthetic or AI-generated phishing content

Unauthorized model download detection

Identify downloads of large model files from HuggingFace, GitHub, or similar sources

AI-related browser automation detection

Detect automated scripts interacting with AI tools

AI-assisted code anomaly detection

Identify code patterns that indicate AI-generated or AI-modified code

AI-generated insider-risk signals

Detect misuse of AI tools for harmful or policy-violating actions

AI-related credential misuse detection

Identify compromised or misused credentials interacting with AI services

AI-related data exfiltration patterns

Detect exfiltration attempts disguised as AI usage

AI-related API abuse detection

Identify excessive or suspicious API calls to AI services

4. GOVERNANCE

AI acceptable use policy

Define what employees may and may not do with AI tools

ShadowAI risk register

Track all identified ShadowAI risks and their mitigation status

Vendor risk scoring

Evaluate AI vendors for security, privacy, and compliance risks

Compliance mapping (GDPR, HIPAA, SOC2...)

Map AI usage to regulatory requirements such as GDPR, HIPAA, SOC2

AI model inventory

Maintain a list of all internal and external AI models used in the organization

AI data classification rules

Define which data types may be sent to AI tools

AI procurement workflow

Require security review before purchasing or adopting AI tools

AI supply-chain assessment

Evaluate third-party AI dependencies and model sources

AI model change-management

Track updates to AI models and their impact on risk

AI red-team testing

Conduct adversarial testing of AI systems to identify vulnerabilities

AI ethics review

Evaluate AI systems for fairness, bias, and transparency

AI lifecycle governance

Manage AI systems from development to retirement

AI dataset governance

Control how training and inference datasets are created, stored, and used

AI transparency documentation

Document how AI systems work, what data they use, and their limitations

AI incident reporting requirements

Define how AI-related incidents must be reported and escalated

5. RESPONSE

ShadowAI IR playbook

Define steps for responding to unauthorized AI usage

Auto-containment rules

Automatically block or isolate risky AI activity

User coaching workflow

Provide corrective guidance to users who violate AI policy

Insider-risk escalation workflow

Escalate AI misuse to security, HR, or legal teams

Automated OAuth revocation

Automatically revoke access to unauthorized AI apps

Automated network isolation

Isolate devices exhibiting risky AI behavior

Vendor disablement process

Rapidly disable access to risky AI vendors

Post-incident AI usage review

Analyze AI usage after an incident to prevent recurrence

AI-specific forensics procedures

Collect evidence from AI logs, prompts, and outputs

AI-related legal/regulatory workflow

Handle legal notifications for AI-related incidents